

LAPORAN AUDIT INTERNAL

SISTEM MANAJEMEN KEAMANAN INFORMASI

Berdasarkan ISO/IEC 27001:2022 dan ISO 19011:2018

PT JELAJAH DUNIA

Lingkup Sertifikasi:

*“Sistem Manajemen Keamanan Informasi dalam Operasional
E-Commerce Pemesanan Tiket Online PT Jelajah Dunia”*

Nomor Laporan	LAI/ISMS/001/I/2026
Jenis Audit	Audit Internal - Pihak Pertama
Periode Audit	6 - 24 Januari 2026
Tanggal Audit	24 Januari 2026
Ketua Audit Team	Syahril Arfian Almazril
Client Audit	Top Management PT Jelajah Dunia
Standar Acuan	ISO/IEC 27001:2022; ISO 19011:2018; Kebijakan Internal PT Jelajah Dunia

Disusun untuk persiapan External Audit ISO 27001 Surveillance 1 - Juni 2026

Daftar Isi

Daftar Isi	2
1. Ringkasan Eksekutif	3
2. Sasaran Audit	4
3. Ruang Lingkup Audit	4
4. Kriteria Audit	5
4.1 Standar Eksternal	5
4.2 Kebijakan Internal PT Jelajah Dunia	5
5. Identifikasi Tim Audit dan Peserta Auditi	5
5.1 Tim Audit Internal	5
5.2 Peserta Auditi	6
7. Metodologi Audit	7
7.1 Metode Pengumpulan Bukti Audit	7
7.2 Klasifikasi Temuan	8
7.3 Format Pelaporan Temuan - CPLOR	8
8. Ringkasan Temuan Audit	9
9. Detail Temuan Audit (Format CPLOR)	10
9.1 Temuan F-01 - Background Screening (SKCK Karyawan Baru)	10
9.2 Temuan F-02 - Risk Assessment Pasca-Relokasi Kantor	12
9.3 Temuan F-03 - Access Review Q3 dan Q4 2025	14
9.4 Temuan F-04 - Change Request CR 1010 (Firewall Rule)	16
10. Kesimpulan Audit	18
10.1 Pemenuhan Sasaran Audit	18
10.2 Status Kepatuhan	18
10.3 Tren dan Pola Akar Penyebab	18
10.4 Penilaian Kesiapan Surveillance Audit	18
11. Tindak Lanjut dan Timeline	18
11.1 Target Timeline Penyelesaian	19
12. Pernyataan Risiko Pengambilan Sampel	19
13. Perbedaan Pendapat (Dissenting Opinions)	19
14. Penutup dan Pengesahan	20
Distribusi Laporan	20

1. Ringkasan Eksekutif

Audit internal Sistem Manajemen Keamanan Informasi (SMKI) PT Jelajah Dunia telah dilaksanakan pada periode 6 – 24 Januari 2026 sebagai langkah persiapan menghadapi *External Audit ISO 27001 Surveillance 1* yang direncanakan pada Juni 2026. Audit mencakup empat area fokus, yaitu Human Capital (background screening), IT GRC (risk management dan access control), serta Engineering (change management).

Berdasarkan hasil peninjauan dokumen, wawancara, dan observasi lapangan, tim audit mengidentifikasi 4 (empat) temuan ketidaksesuaian (non-conformity) yang seluruhnya diklasifikasikan sebagai Major Non-Conformity. Temuan tersebut mencakup pelanggaran terhadap klausul mandatori ISO/IEC 27001:2022 (Clause 8.2 Information Security Risk Assessment) dan kontrol Annex A (5.15, 5.18, 6.1, 8.32), serta penyimpangan terhadap kebijakan internal PT Jelajah Dunia.

Pola Akar Penyebab. Tiga dari empat temuan memiliki akar penyebab yang saling terkait, yaitu keterbatasan kapasitas SDM (Tim IT GRC hanya satu anggota sejak Q3 2025; turnover PIC onboarding HC pada September 2025) dan kelemahan enforcement kontrol sistemik (tidak adanya gating otomatis pada proses onboarding dan change management, serta tidak adanya pemicu RA berbasis significant change event).

Rekomendasi Strategis. Tim audit merekomendasikan kepada Top Management untuk segera menetapkan Corrective Action Plan (CAP) dengan target penyelesaian sebelum Mei 2026, melaksanakan follow-up audit pada April 2026, serta membahas seluruh temuan dalam Management Review Meeting (MRM) terdekat sebagai bagian dari pemenuhan Clause 9.3 ISO/IEC 27001:2022.

Total Temuan	Major NC	Minor NC / OFI
4	4	0 / 0

2. Sasaran Audit

Sasaran audit internal ini ditetapkan selaras dengan arahan strategis Top Management dan kebijakan SMKI PT Jelajah Dunia, sebagai berikut:

1. Menilai efektivitas implementasi Sistem Manajemen Keamanan Informasi (SMKI) di seluruh lingkup operasional PT Jelajah Dunia.
2. Memastikan kepatuhan terhadap persyaratan klausul mandatori (Clause 4–10) dan kontrol Annex A ISO/IEC 27001:2022 yang relevan, serta terhadap kebijakan internal perusahaan.
3. Mengidentifikasi gap dan area perbaikan agar dapat ditindaklanjuti sebelum pelaksanaan External Audit Surveillance 1 pada Juni 2026.

3. Ruang Lingkup Audit

Lingkup Sertifikasi ISMS: *“Sistem Manajemen Keamanan Informasi dalam Operasional E-Commerce Pemesanan Tiket Online PT Jelajah Dunia”.*

Lokasi Audit: Kantor Pusat PT Jelajah Dunia, Gedung 456, Pasar Minggu, Jakarta Selatan, DKI Jakarta.

Area yang Diaudit:

No.	Departemen	Topik Audit	PIC Audit
1	Human Capital	Background Screening (SKCK karyawan baru)	Rina Clarissa (Head of HC); Lorent Aprilia (HC Staff)
2	IT GRC	Risk Management - Risk Assessment pasca-relokasi kantor	Tim IT GRC
3	IT GRC	Access Control - Access Review berkala GCP, Critical Apps, GitHub	Tim IT GRC
4	Engineering	Change Management - proses Change Request (CR)	Head of Engineering; Tim Engineering

Batasan Audit. Audit ini hanya mencakup empat topik di atas dan tidak merepresentasikan keseluruhan lingkup ISMS. Sesuai d studi kasus, area yang tidak diinformasikan tidak otomatis disimpulkan sebagai non-conformity; pemeriksaan komprehensif menyeluruh terhadap seluruh klausul mandatori dan kontrol Annex A dilakukan pada audit eksternal.

4. Kriteria Audit

4.1 Standar Eksternal

ISO/IEC 27001:2022 - Klausul Mandatori:

- Clause 6.1.2 - Information Security Risk Assessment
- Clause 8.2 - Information Security Risk Assessment (operational)

ISO/IEC 27001:2022 - Annex A:

- A.5.15 Access Control
- A.5.18 Access Right
- A.6.1 Screening
- A.6.2 Terms and Conditions of Employment
- A.8.20 Networks Security
- A.8.32 Change Management

ISO 19011:2018 - *Guidelines for auditing management systems* sebagai acuan tata laksana program dan pelaksanaan audit.

4.2 Kebijakan Internal PT Jelajah Dunia

Nomor Kebijakan	Judul Kebijakan	Peninjauan Terakhir
PNP/HC/012/2023 v1.2	Kebijakan Pemeriksaan Latar Belakang Kandidat	27 Desember 2024
PNP/IT/002/2023 v1.1	Kebijakan Manajemen Akses	22 September 2025
PNP/IT/004/2023 v1.1	Kebijakan Manajemen Perubahan	22 September 2025

5. Identifikasi Tim Audit dan Peserta Audit

5.1 Tim Audit Internal

Peran	Nama	Penugasan
Ketua Tim Audit Internal	Syahril Arfian Almazril	Lead Auditor

5.2 Peserta Auditi

Peran	Nama	Departemen
Head of Human Capital	Rina Clarissa	Human Capital
Human Capital Staff	Lorent Aprilia	Human Capital
IT GRC Lead	Tim IT GRC	IT GRC
Head of Engineering	PIC Engineering	Engineering
Head of Operations	PIC Operations	Operations

6. Jadwal dan Lokasi Aktivitas Audit

Fase	Periode	Aktivitas Utama
Peninjauan Dokumen	6 - 10 Januari 2026	Review kebijakan, prosedur, risk register, access review report, sampel change request, dokumen onboarding karyawan baru.
Wawancara dan Observasi	13 - 17 Januari 2026	Wawancara dengan pemilik proses (Head of Engineering, Head of Operations, Head of Human Capital, IT GRC); observasi kontrol akses fisik dan audit trail sistem.
Penyusunan dan Penyampaian Laporan	20 - 24 Januari 2026	Penyusunan laporan audit; closing meeting; distribusi laporan kepada Top Management dan pihak berkepentingan.

Lokasi Audit: Kantor Pusat PT Jelajah Dunia, Gedung 456, Pasar Minggu, Jakarta Selatan.

7. Metodologi Audit

Audit dilaksanakan dengan mengacu pada panduan ISO 19011:2018 - Guidelines for auditing management systems, dengan pendekatan berbasis risiko (*risk-based approach*) dan menjunjung lima prinsip audit, yaitu: presentasi adil, bersikap profesional, kerahasiaan, independensi, dan pendekatan berbasis bukti.

7.1 Metode Pengumpulan Bukti Audit

1. Tinjauan dokumentasi - pemeriksaan kebijakan internal, prosedur operasional, dokumen risk assessment, access review report, change request, dan rekaman onboarding.
2. Wawancara - sesi tanya-jawab terstruktur dengan pemilik proses dan PIC terkait pada periode 13–17 Januari 2026.
3. Observasi langsung - pengamatan penerapan kontrol fisik dan logikal di lapangan.
4. Pengambilan sampel - sampling terhadap 10 data karyawan baru, 4 kuartal access review report (Q1–Q4 2025), dan 5 sampel Change Request.

7.2 Klasifikasi Temuan

Klasifikasi	Definisi
Major NC	Ketidaksesuaian sistemik, melibatkan kegagalan klausul mandatori, atau berdampak signifikan terhadap efektivitas SMKI dan kelangsungan sertifikasi.
Minor NC	Ketidaksesuaian terisolasi dengan dampak terbatas dan dapat diperbaiki dalam waktu singkat.
OFI	Opportunity for Improvement - peluang peningkatan tanpa pelanggaran kriteria audit.

7.3 Format Pelaporan Temuan - CPLOR

Setiap temuan dilaporkan menggunakan kaidah CPLOR untuk memastikan temuan jelas, berbasis bukti, dan mudah ditindaklanjuti:

- **C - Compliance:** pernyataan kepatuhan yang sudah dipenuhi auditi sebagai konteks.
- **P - Problem:** kesenjangan atau ketidaksesuaian yang teridentifikasi.
- **L - Location:** area spesifik dalam lingkup ISMS tempat masalah ditemukan.
- **O - Objective:** bukti konkret berupa audit trail, dokumen, hasil wawancara, atau observasi.
- **R - Reference:** klausul ISO/IEC 27001:2022, kebijakan internal, atau peraturan perundang-undangan terkait.

Setiap temuan juga dilengkapi dengan analisis Risiko dan Rekomendasi tindakan korektif/perbaikan.

8. Ringkasan Temuan Audit

Kode	Area	Temuan	Klasifikasi	Referensi Utama
F-01	Human Capital	SKCK belum diserahkan oleh 5 dari 10 karyawan baru (50%) periode 1 tahun terakhir.	Major NC	Annex A.6.1; PNP/HC/012/2023
F-02	IT GRC - Risk Mgmt	Risk Assessment belum diperbarui pasca-relokasi kantor (selisih lebih dari 6 bulan).	Major NC	Clause 8.2; Clause 6.1.2
F-03	IT GRC - Access Ctrl	Access review Q3 2025 tidak lengkap dan Q4 2025 belum dilaksanakan.	Major NC	Annex A.5.15; A.5.18; PNP/IT/002/2023
F-04	Engineering	CR 1010 (penambahan firewall rule) diimplementasi di production tanpa persetujuan lengkap.	Major NC	Annex A.8.32; A.8.20; PNP/IT/004/2023

Total: 4 Major Non-Conformity | 0 Minor Non-Conformity | 0 Opportunity for Improvement.

9. Detail Temuan Audit (Format CPLOR)

9.1 Temuan F-01 - Background Screening (SKCK Karyawan Baru)

F-01 - Ketidaklengkapan Pengumpulan SKCK pada Proses Onboarding

Klasifikasi	Major Non-Conformity
Area / Departemen	Human Capital
Tanggal Identifikasi	14 Januari 2026

C - Compliance

PT Jelajah Dunia telah menetapkan Kebijakan Pemeriksaan Latar Belakang Kandidat (PNP/HC/012/2023 v1.2) yang mewajibkan setiap kandidat menyerahkan SKCK valid (diterbitkan maksimal 3 bulan sebelum tanggal pengajuan), dan menetapkan Tim Human Capital sebagai pihak yang bertanggung jawab atas verifikasi dokumen. Dari 10 sampel karyawan baru, 5 (lima) karyawan telah memenuhi persyaratan SKCK, yaitu Ayu Lestari Ramadhani (Mobile Engineer), Bagas Nugroho Santika (Sales & Partnership), Citra Melati Kusumawati (Sales & Partnership), Fitri Nur Aisyah (General Affair), dan Hadi Susanto Aditya (Marketing Manager).

P - Problem

Berdasarkan pemeriksaan data karyawan baru 1 tahun terakhir, ditemukan bahwa 5 dari 10 karyawan baru (50%) tidak menyerahkan SKCK sebagaimana dipersyaratkan oleh kebijakan internal dan ISO/IEC 27001:2022 Annex A.6.1 Screening. Selain itu, tindak lanjut pengumpulan SKCK belum dilaksanakan oleh Tim Human Capital.

L - Location

Departemen Human Capital, Kantor Pusat PT Jelajah Dunia, Gedung 456, Pasar Minggu, Jakarta Selatan. Berkaitan dengan proses onboarding karyawan baru dan arsip dokumen pre-employment.

O - Objective Evidence

Berdasarkan tinjauan data master karyawan baru periode satu tahun terakhir dan konfirmasi via wawancara dengan Lorent Aprilia (Human Capital Staff) dan Rina Clarissa (Head of Human Capital) pada 14 Januari 2026, ditemukan 5 karyawan tanpa SKCK sebagai berikut:

No.	Nama Karyawan	Jabatan	Tanggal Bergabung	SKCK
1	Andi Pratama Wijaya	HR Staff	17 Oktober 2025	Tidak
2	Dewi Maharani Sasmita	IT GRC	16 Oktober 2025	Tidak
3	Eko Budi Prasetyo	iOS Engineer	1 November 2025	Tidak
4	Maya Sari Purnamasari	Finance Staff	18 Desember 2025	Tidak
5	Rendy Kurniawan Putra	Onboarding Specialist	1 Januari 2026	Tidak

Konfirmasi via wawancara: Auditi mengakui bahwa (1) tindak lanjut pengumpulan SKCK terlupakan oleh Tim HC; dan (2) terdapat pengunduran diri karyawan HC PIC onboarding pada September 2025 yang menyebabkan diskontinuitas proses pengumpulan dokumen pendukung onboarding.

R - Reference

- **ISO/IEC 27001:2022 Annex A.6.1 Screening** - Background verification checks on all candidates to become personnel shall be carried out prior to joining the organization and on an ongoing basis...
- **Kebijakan Internal PNP/HC/012/2023 v1.2** - Ketentuan butir 1 (Pemeriksaan Rekam Jejak Kriminal) dan butir 4 (Proses Verifikasi).

Risiko

- **Risiko keamanan personel (insider threat).** Potensi rekrutmen kandidat dengan rekam jejak kriminal yang dapat menimbulkan ancaman, khususnya pada posisi IT GRC, iOS Engineer, dan Finance Staff yang memiliki akses sensitif terhadap sistem dan data keuangan.
- **Risiko kepatuhan.** Potensi temuan Major NC pada External Surveillance Audit Juni 2026 yang berdampak pada kelangsungan sertifikasi ISO 27001:2022.
- **Risiko operasional.** Kelemahan proses onboarding yang berulang akibat tidak adanya kontrol gating otomatis dan ketiadaan SLA tindak lanjut.

Rekomendasi

- **Jangka pendek (≤ 30 hari).** Tim HC segera melakukan recall dan mengumpulkan SKCK dari 5 karyawan terdampak, dengan SLA penyerahan maksimal 14 hari kerja sejak tanggal follow-up resmi.
- **Jangka menengah (≤ 60 hari).** Implementasi onboarding checklist digital (HRIS atau workflow system) yang menempatkan SKCK sebagai blocking item sebelum status karyawan berubah menjadi active.
- **Jangka panjang.** Tetapkan backup PIC untuk setiap proses kritikal HC guna mencegah diskontinuitas akibat turnover. Lakukan tinjauan ulang Kebijakan PNP/HC/012/2023 untuk menambahkan klausul SLA tindak lanjut dan mekanisme eskalasi.

9.2 Temuan F-02 - Risk Assessment Pasca-Relokasi Kantor

F-02 - Risk Assessment Belum Diperbarui Setelah Perubahan Signifikan

Klasifikasi	Major Non-Conformity
Area / Departemen	IT Governance, Risk, and Compliance (GRC) - Risk Management
Tanggal Identifikasi	6 Januari 2026

C - Compliance

PT Jelajah Dunia telah melaksanakan *Risk Assessment* (RA) terakhir pada **April 2025** dengan dokumentasi yang tersedia dan pemilik risiko (risk owner) yang teridentifikasi. Hal ini menunjukkan bahwa proses RA telah dirancang dan dijalankan secara berkala sesuai pendekatan manajemen risiko yang ditetapkan.

P - Problem

Risk Assessment belum diperbarui untuk mencerminkan **perubahan signifikan (significant change)** berupa relokasi kantor utama dari Gedung 123, Bojongsoang, Bandung, Jawa Barat ke Gedung 456, Pasar Minggu, Jakarta Selatan yang berlangsung Juni–Agustus 2025. Pada saat audit (6 Januari 2026), selisih waktu antara perubahan signifikan dan tanggal audit telah mencapai **lebih dari 6 (enam) bulan** tanpa pemutakhiran RA. Seluruh risiko dalam dokumen RA eksisting masih merujuk pada profil ancaman dan lingkungan kantor lama di Bandung.

L - Location

Departemen IT Governance, Risk, and Compliance (GRC), berkaitan dengan dokumen Risk Register dan Risk Assessment PT Jelajah Dunia.

O - Objective Evidence

Tinjauan dokumen Risk Assessment April 2025: seluruh entri risiko, threat scenario, dan kontrol kompensasi mengacu pada lokasi Gedung 123 Bojongsoang, Bandung.

Kronologi Relokasi (terdokumentasi):

- **Juni 2025:** Tim operasional mulai pindah ke kantor baru di Jakarta.
- **Juli 2025:** Infrastruktur IT selesai dipindahkan ke lokasi baru.
- **Agustus 2025:** Operasional perusahaan di Bandung resmi dihentikan.

Per 6 Januari 2026: tidak ditemukan dokumen RA pemutakhiran maupun delta risk assessment yang mengakomodasi konteks lokasi Jakarta, mencakup profil ancaman fisik, vendor data center/utilitas baru, regulasi daerah, akses fisik kantor baru, atau aspek terkait lainnya.

R - Reference

- **ISO/IEC 27001:2022 Clause 8.2** - The organization shall perform information security risk assessments at planned intervals or when significant changes are proposed or occur, taking account of the criteria established in 6.1.2 a).
- **ISO/IEC 27001:2022 Clause 6.1.2** - Persyaratan proses risk assessment yang konsisten, valid, dan dapat dibandingkan.

Risiko

- **Ancaman baru yang tidak terdokumentasi.** Lokasi Jakarta memiliki profil risiko berbeda (kepadatan urban, tingkat kejahatan siber, risiko banjir/gangguan listrik, regulasi daerah, dependensi vendor baru) yang tidak tercakup dalam RA eksisting.
- **Ketidaktepatan kontrol kompensasi.** Kontrol yang dirancang untuk konteks Bandung mungkin tidak memadai atau berlebihan untuk konteks Jakarta.
- **Risiko pada audit eksternal.** Pelanggaran klausul mandatori 8.2 umumnya menjadi show-stopper dalam surveillance audit dan dapat memicu Major NC dengan tindak lanjut wajib sebelum sertifikat dipertahankan.

Rekomendasi

- **Jangka pendek (≤ 30 hari).** Tim IT GRC segera melaksanakan risk assessment refresh dengan ruang lingkup khusus dampak relokasi: lokasi fisik baru, vendor lokal, kontrol akses gedung, kontinuitas bisnis, dan dependensi infrastruktur. Hasil pengkinian disahkan oleh risk owner.
- **Jangka menengah (≤ 60 hari).** Selaraskan hasil RA baru dengan Statement of Applicability (SoA), Risk Treatment Plan, dan Business Continuity Plan. Lakukan Management Review Meeting untuk pengesahan oleh Top Management.
- **Jangka panjang.** Tetapkan pemicu RA berbasis event-driven (bukan hanya berbasis kalender) dalam metodologi RA, disertai daftar trigger event eksplisit seperti relokasi, akuisisi, perubahan teknologi material, atau insiden major.

9.3 Temuan F-03 - Access Review Q3 dan Q4 2025

F-03 - Ketidaksesuaian Pelaksanaan Access Review Berkala

Klasifikasi	Major Non-Conformity
Area / Departemen	IT Governance, Risk, and Compliance (GRC) - Access Control
Tanggal Identifikasi	8 Januari 2026

C - Compliance

PT Jelajah Dunia telah menetapkan **Kebijakan Manajemen Akses (PNP/IT/002/2023 v1.1)** yang mewajibkan access review setiap kuartal terhadap seluruh sistem produksi, aplikasi kritis, dan repository. Pada Q1 dan Q2 2025, access review telah dilaksanakan secara lengkap mencakup Google Cloud Platform (GCP), Critical Applications, dan GitHub, sesuai ketentuan kebijakan.

P - Problem

Pelaksanaan access review pada **Q3 2025 tidak lengkap** (hanya mencakup GCP tanpa critical apps dan GitHub), dan pada **Q4 2025 belum dilaksanakan sama sekali**. Total terdapat **2 (dua) kuartal berturut-turut** yang menyimpang dari kebijakan internal dan persyaratan kontrol akses ISO/IEC 27001:2022.

L - Location

Departemen IT Governance, Risk, and Compliance (GRC). Sistem terdampak: Google Cloud Platform (GCP), Critical Business Applications, dan GitHub Repository.

O - Objective Evidence

Periode	Lingkup Sesuai Kebijakan	Lingkup Aktual	Status
Q1 2025	GCP, Critical Apps, GitHub	GCP, Critical Apps, GitHub	Conform
Q2 2025	GCP, Critical Apps, GitHub	GCP, Critical Apps, GitHub	Conform
Q3 2025	GCP, Critical Apps, GitHub	Hanya GCP	Non-Conform
Q4 2025	GCP, Critical Apps, GitHub	Belum dilaksanakan; dijadwalkan Januari 2026	Non-Conform

Konfirmasi via wawancara dengan Tim IT GRC: sejak Q3 2025 jumlah anggota Tim IT GRC berkurang menjadi hanya 1 (satu) orang. Akibat keterbatasan sumber daya dan prioritas tugas lain, proses access review tidak dapat dilaksanakan sesuai rencana. Tidak ditemukan bukti adanya eskalasi resmi kepada manajemen sebagaimana diwajibkan oleh butir 3 kebijakan (Monitoring dan Eskalasi).

R - Reference

- **ISO/IEC 27001:2022 Annex A.5.15 Access Control** - Rules to control physical and logical access to information and other associated assets shall be established and implemented based on business and information security requirements.
- **ISO/IEC 27001:2022 Annex A.5.18 Access Right** - Access rights to information and other associated assets shall be provisioned, reviewed, modified and removed in accordance with the organization's topic-specific policy on and rules for access control.
- **Kebijakan Internal PNP/IT/002/2023 v1.1** - Butir 1 (Access Review Berkala), butir 3 (Monitoring dan Eskalasi).

Risiko

- **Akses stale dan orphan account.** Akun karyawan yang telah resign atau berubah peran berpotensi tidak tercabut tepat waktu, menimbulkan unauthorized access ke sistem produksi dan kode sumber.
- **Privilege creep.** Akumulasi hak akses berlebihan yang tidak terverifikasi, melanggar prinsip least privilege.
- **Insider threat terhadap GitHub repository.** Salah satu aset paling kritis karena memuat source code aplikasi produksi e-commerce.
- **Kegagalan mekanisme eskalasi.** Keterbatasan sumber daya yang tidak dieskalasi secara formal menunjukkan kelemahan tata kelola dan komunikasi internal Tim GRC dengan manajemen.

Rekomendasi

- **Jangka pendek (≤ 21 hari).** Selesaikan access review Q4 2025 untuk seluruh sistem (GCP, Critical Apps, GitHub) dengan prioritas tertinggi pada GitHub. Lakukan retroactive review untuk gap Q3 2025 pada Critical Apps dan GitHub.
- **Jangka menengah (≤ 60 hari).** Penambahan kapasitas Tim IT GRC (rekrutmen atau cross-functional assignment) sesuai resource plan. Sebagai quick win, lakukan otomatisasi access review report generation dari sistem IAM untuk mengurangi manual effort.
- **Jangka panjang.** Implementasi Identity Governance & Administration (IGA) tool dengan kemampuan automated access certification campaign dan continuous monitoring. Perkuat mekanisme eskalasi dengan KPI eksplisit dan escalation path yang terdokumentasi.

9.4 Temuan F-04 - Change Request CR 1010 (Firewall Rule)

F-04 - Implementasi Perubahan di Production Tanpa Persetujuan Lengkap

Klasifikasi	Major Non-Conformity
Area / Departemen	Engineering - Change Management
Tanggal Identifikasi	16 Januari 2026

C - Compliance

PT Jelajah Dunia telah menetapkan **Kebijakan Manajemen Perubahan (PNP/IT/004/2023 v1.1)** yang mewajibkan seluruh perubahan di lingkungan produksi melalui proses formal Change Request (CR) dengan persetujuan pihak berwenang. Dari 5 (lima) sampel CR yang ditinjau, **4 (empat) CR** telah menjalankan proses persetujuan dengan benar, yaitu: CR 1011 (Deploy app ABCD v2.1), CR 1000 (perubahan konfigurasi password Google Workspace), CR 997 (security patch database “db-abcd-01”), dan CR 956 (security patch akibat temuan VAPT aplikasi ABCD).

P - Problem

CR 1010 - Penambahan firewall rule untuk aset “fw-xyz-01” telah **diimplementasikan pada lingkungan production** untuk memblokir traffic masuk dan keluar, namun **belum mendapatkan persetujuan lengkap** dari seluruh approver yang dipersyaratkan, yaitu Infrastructure Lead dan Business Operations Lead. Implementasi perubahan di production tanpa persetujuan lengkap secara langsung melanggar butir 2 (Persetujuan Wajib) kebijakan manajemen perubahan.

L - Location

Tim Engineering. Aset terdampak: perangkat firewall “fw-xyz-01” pada lingkungan production.

O - Objective Evidence

- **Pemeriksaan konfigurasi production firewall “fw-xyz-01”:** ditemukan beberapa firewall rule aktif yang memblokir traffic masuk dan keluar sesuai cakupan CR 1010.
- **Tinjauan dokumentasi CR 1010 pada sistem manajemen perubahan:** status persetujuan belum lengkap - Infrastructure Lead dan Business Operations Lead belum memberikan approval.
- **Mismatch terverifikasi:** implementasi telah berlangsung di production sementara CR 1010 berstatus belum disetujui penuh.

R - Reference

- **ISO/IEC 27001:2022 Annex A.8.32 Change Management** - Changes to information processing facilities and information systems shall be subject to change management procedures.

- **ISO/IEC 27001:2022 Annex A.8.20 Networks Security** - Networks and network devices shall be secured, managed and controlled to protect information in systems and applications.
- **Kebijakan Internal PNP/IT/004/2023 v1.1** - Butir 1 (Proses Formal) dan butir 2 (Persetujuan Wajib).

Risiko

- **Risiko ketersediaan layanan (availability).** Firewall rule yang tidak melalui validasi Business Operations Lead berpotensi memblokir traffic sah dan menyebabkan gangguan operasional e-commerce pemesanan tiket online.
- **Risiko integritas konfigurasi jaringan.** Perubahan tanpa peer review lengkap meningkatkan probabilitas misconfiguration yang dapat dimanfaatkan oleh penyerang.
- **Risiko audit trail dan akuntabilitas.** Penyimpangan ini menciptakan celah dalam jejak tata kelola perubahan yang dapat berulang jika tidak diperbaiki secara sistemik.
- **Risiko bypass control sistemik.** Jika satu CR berhasil melewati gate persetujuan, hal serupa mungkin telah terjadi pada CR lain di luar sampel - perluasan investigasi diperlukan.

Rekomendasi

- **Jangka pendek (≤ 14 hari).** Lakukan retroactive approval CR 1010 dengan tinjauan teknis dan bisnis oleh Infrastructure Lead dan Business Operations Lead. Jika approval tidak diberikan, lakukan rollback terhadap firewall rule terkait.
- **Jangka menengah (≤ 45 hari).** Lakukan extended sampling terhadap CR di luar 5 sampel awal (minimal 20 CR tambahan dalam 12 bulan terakhir) untuk memastikan tidak ada penyimpangan serupa yang belum terdeteksi.
- **Jangka panjang.** Implementasi technical enforcement pada sistem manajemen perubahan berupa workflow gating - perubahan tidak dapat dieksekusi di production jika status approval belum lengkap. Integrasikan dengan Infrastructure-as-Code (IaC) pipeline dan CI/CD dengan policy-as-code untuk firewall changes.

10. Kesimpulan Audit

10.1 Pemenuhan Sasaran Audit

Sasaran audit telah tercapai. Tim audit memperoleh akses informasi yang memadai dan dapat mengevaluasi efektivitas implementasi SMKI pada empat area yang dilingkup.

10.2 Status Kepatuhan

Berdasarkan bukti audit yang dikumpulkan, PT Jelajah Dunia belum sepenuhnya memenuhi persyaratan ISO/IEC 27001:2022 dan kebijakan internal pada area yang dilingkup. Teridentifikasi 4 (empat) Major Non-Conformity yang seluruhnya terkonfirmasi melalui pengumpulan bukti dan wawancara dengan auditi.

10.3 Tren dan Pola Akar Penyebab

Tiga dari empat temuan (F-01, F-02, F-03) memiliki akar penyebab serupa, yaitu kelemahan tata kelola dan keterbatasan kapasitas SDM. Tim audit mengidentifikasi tiga pola sistemik:

1. Keterbatasan sumber daya manusia - Tim IT GRC hanya satu anggota sejak Q3 2025; turnover PIC onboarding HC pada September 2025.
2. Kelemahan mekanisme follow-up dan eskalasi - tidak adanya checklist gating pada proses onboarding HC; tidak adanya eskalasi formal atas keterbatasan kapasitas access review.
3. Kelemahan enforcement kontrol di sistem - Change Request dapat dieksekusi tanpa approval lengkap; tidak ada pemicu RA berbasis significant change event.

10.4 Penilaian Kesiapan Surveillance Audit

Tanpa tindakan korektif yang segera dan terstruktur, perusahaan berpotensi menerima Major Non-Conformity pada External Surveillance Audit Juni 2026, yang dapat berdampak pada kelangsungan sertifikasi ISO/IEC 27001:2022. Tim audit menilai bahwa keempat temuan dapat diselesaikan tepat waktu apabila Corrective Action Plan (CAP) ditetapkan dan dijalankan dengan prioritas oleh manajemen.

11. Tindak Lanjut dan Timeline

Tim audit merekomendasikan kepada Top Management untuk menjalankan tindakan berikut:

1. Menetapkan Corrective Action Plan (CAP) untuk setiap temuan dengan PIC, root cause analysis, dan target penyelesaian, paling lambat 14 hari kerja sejak laporan diterima.
2. Menjalankan follow-up audit atas pelaksanaan CAP pada bulan April 2026, untuk memastikan efektivitas tindakan korektif sebelum External Surveillance Audit Juni 2026.

3. Membahas seluruh temuan dalam Management Review Meeting terdekat sebagai bagian dari pemenuhan Clause 9.3 ISO/IEC 27001:2022.

11.1 Target Timeline Penyelesaian

Temuan	Tindakan Korektif Utama	Target Penyelesaian	Verifikasi
F-01	Recall SKCK 5 karyawan + checklist gating digital	Februari 2026	Maret 2026
F-02	Risk assessment refresh pasca-relokasi + sinkronisasi SoA dan BCP	Maret 2026	April 2026
F-03	Penyelesaian access review Q4 + retroaktif Q3 + penambahan kapasitas tim	Februari 2026 (retroaktif); berkelanjutan	April 2026
F-04	Retroactive approval CR 1010 + extended sampling + workflow gating	Februari 2026 (perbaikan); April 2026 (sistemik)	April 2026

12. Pernyataan Risiko Pengambilan Sampel

Sesuai prinsip audit berbasis bukti dalam ISO 19011:2018, audit ini didasarkan pada metode sampling: 10 sampel karyawan baru, 4 kuartal access review report, dan 5 sampel Change Request. Terdapat risiko inherent bahwa bukti audit yang diperiksa mungkin tidak sepenuhnya representatif terhadap keseluruhan populasi. Auditi disarankan melakukan self-assessment terhadap populasi penuh atas temuan-temuan dengan pola sistemik (khususnya F-01 dan F-04) untuk memastikan tidak ada kasus serupa di luar sampel.

13. Perbedaan Pendapat (Dissenting Opinions)

Tidak terdapat perbedaan pendapat yang tidak terselesaikan antara tim audit dan auditi. Seluruh temuan telah dikomunikasikan dalam sesi closing meeting pada tanggal 24 Januari 2026 dan dikonfirmasi oleh pemilik proses terkait.

14. Penutup dan Pengesahan

Laporan ini disusun secara objektif berdasarkan bukti yang dikumpulkan selama periode audit 6–24 Januari 2026. Seluruh isi laporan bersifat rahasia dan hanya didistribusikan kepada pihak berkepentingan sesuai program audit. Tim audit mengapresiasi kooperasi seluruh auditi selama proses audit berlangsung dan berharap rekomendasi dalam laporan ini dapat memperkuat efektivitas SMKI PT Jelajah Dunia menjelang External Audit Surveillance 1 pada Juni 2026.

Disusun oleh,
Tim Audit Internal

Diterima oleh,
Top Management PT Jelajah Dunia

Syahril Arfian Almazril
Ketua Tim Audit Internal
Tanggal: 24 Januari 2026

[Nama Top Management]
Management Representative
Tanggal: _____

Distribusi Laporan

1. Top Management PT Jelajah Dunia
2. Head of Human Capital
3. Head of Engineering
4. IT Governance, Risk, and Compliance (GRC)
5. Arsip Internal Audit